LAB 5

Static Code Analysis

Loan Eligibility and EMI Calculator | Consolidated Submission

30 October 2026

Introduction

Static code analysis checks source code without executing it. It helps find likely defects, security risks, and style problems early. In this lab, the supplied loan calculator was reviewed with three complementary Python tools.

The three tools

Pylint reviews Python quality and common logic-risk patterns, including unused code, dangerous defaults, naming, and documentation.

Bandit scans Python source for common security problems such as unsafe data handling, weak randomness, insecure network transport, and embedded secrets.

Flake8 checks Python formatting and style, including whitespace, line length, and unused imports.

Work completed

The EMI and loan-capacity formulas were corrected, invalid products and inputs are rejected, application records use JSON, identifiers use a cryptographically secure source, and bureau/mail transfers use TLS with credentials provided through environment settings. The final demo ran successfully. Pylint scored **10.00/10**; Bandit reported **no issues**; Flake8 reported **no violations**.

Commit sequence

4e1ef3d - Pylint and calculation fixes
6624787 - Bandit security fixes
171e367 - Flake8 cleanup, reports, and reflection

Individual GitHub repository

https://github.com/duplicatenode/SE-Labs-PES1UG24CS422

Before Fixes: Tool Findings

Screenshots rendered from the saved scanner output. The full, unabridged contents of each report are included in the appendices.

Pylint

BEFORE FIXES - PYLINT

```
$ python -m pylint loan_calculator.py
************* Module loan_calculator
loan_calculator.py:79:0: C0325: Unnecessary parens after 'return' keyword (superfluous-parens)
loan_calculator.py:95:0: C0301: Line too long (113/100) (line-too-long)
loan_calculator.py:1:0: C0114: Missing module docstring (missing-module-docstring)
loan_calculator.py:14:0: C0116: Missing function or method docstring (missing-function-docstring)
loan_calculator.py:14:0: C0103: Function name "calculateEMI" doesn't conform to snake_case naming style (invalid-
   name)
loan_calculator.py:20:0: C0116: Missing function or method docstring (missing-function-docstring)
loan_calculator.py:20:0: C0103: Function name "checkEligibility" doesn't conform to snake_case naming style
   (invalid-name)
loan_calculator.py:20:0: W0102: Dangerous default value [] as argument (dangerous-default-value)
loan_calculator.py:20:0: R0913: Too many arguments (6/5) (too-many-arguments)
loan_calculator.py:20:0: R0917: Too many positional arguments (6/5) (too-many-positional-arguments)
loan_calculator.py:28:4: R1703: The if statement can be replaced with 'return bool(test)' (simplifiable-if-
   statement)
loan_calculator.py:28:4: R1705: Unnecessary "else" after "return", remove the "else" and de-indent the code inside
   it (no-else-return)
loan_calculator.py:28:7: R1714: Consider merging these comparisons with 'in' by using 'loan_type in ('home', 'car',
   'personal')'. Use a set instead if elements are hashable. (consider-using-in)
... excerpt continues in the full report appendix ...
```

Bandit

BEFORE FIXES - BANDIT

```
$ python -m bandit -r loan_calculator.py
>> Issue: [B402:blacklist] A FTP-related module is being imported.  FTP is considered insecure. Use SSH/SFTP/SCP or
   some other encrypted protocol.
   Severity: High   Confidence: High
   CWE: CWE-319 (https://cwe.mitre.org/data/definitions/319.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.html#b402-import-ftplib
   Location: .\loan_calculator.py:3:0
>> Issue: [B302:blacklist] Deserialization with the marshal module is possibly dangerous.
   Severity: Medium   Confidence: High
   CWE: CWE-502 (https://cwe.mitre.org/data/definitions/502.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b302-marshal
   Location: .\loan_calculator.py:64:19
>> Issue: [B107:hardcoded_password_default] Possible hardcoded password: 'Bureau#2024'
   Severity: Low   Confidence: Medium
   CWE: CWE-259 (https://cwe.mitre.org/data/definitions/259.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b107_hardcoded_password_default.html
   Location: .\loan_calculator.py:67:0
>> Issue: [B321:blacklist] FTP-related functions are being called. FTP is considered insecure. Use SSH/SFTP/SCP or
   some other encrypted protocol.
   Severity: High   Confidence: High
   CWE: CWE-319 (https://cwe.mitre.org/data/definitions/319.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b321-ftplib
   Location: .\loan_calculator.py:68:10
... excerpt continues in the full report appendix ...
```

Before Fixes: Tool Findings (continued)

Flake8

BEFORE FIXES - FLAKE8

```
$ python -m flake8 loan_calculator.py
Installed 4 packages in 253ms
loan_calculator.py:2:1: F401 'math' imported but unused
loan_calculator.py:14:1: E302 expected 2 blank lines, found 1
loan_calculator.py:20:1: E302 expected 2 blank lines, found 1
loan_calculator.py:20:80: E501 line too long (85 > 79 characters)
loan_calculator.py:33:1: E302 expected 2 blank lines, found 1
loan_calculator.py:40:1: E302 expected 2 blank lines, found 1
loan_calculator.py:50:1: E302 expected 2 blank lines, found 1
loan_calculator.py:53:1: E302 expected 2 blank lines, found 1
loan_calculator.py:55:80: E501 line too long (88 > 79 characters)
loan_calculator.py:61:1: E302 expected 2 blank lines, found 1
loan_calculator.py:67:1: E302 expected 2 blank lines, found 1
loan_calculator.py:70:80: E501 line too long (84 > 79 characters)
loan_calculator.py:73:1: E302 expected 2 blank lines, found 1
loan_calculator.py:76:1: E302 expected 2 blank lines, found 1
loan_calculator.py:78:80: E501 line too long (83 > 79 characters)
loan_calculator.py:81:1: E302 expected 2 blank lines, found 1
loan_calculator.py:93:1: E302 expected 2 blank lines, found 1
```

Issue Identification and Fixes

The table prioritizes security and functional correctness findings, followed by maintainability and style issues. Line numbers refer to the original file.

Issue	Type	Line(s)	Description	Fix Approach
Plaintext FTP bureau transfer	High / Bandit B402, B321	3, 67-71	FTP sends credentials and report data without transport encryption.	Replaced FTP with HTTPS PUT, certificate validation, and a bearer token supplied through environment configuration.
EMI uses percentage as a whole rate	High / logic defect	14, 95	The demo passed 9 for 9%, producing an EMI of 375,000 instead of about 10,379 per month.	Standardized annual rates as decimals, used the monthly rate in the amortization formula, handled zero interest, and updated the demo.
Unknown product type could be approved	Medium / logic defect	20-31, 96	A high income or score returned approval before checking the loan type; the demo approved crypto.	Validate the supported product and input ranges before making an eligibility decision.
Maximum principal ignored interest	Medium / Pylint W0613	33-37, 97	annual_rate was unused and the function multiplied available EMI by months, overstating affordable principal.	Use the present value of monthly payments at the supplied rate, with a separate zero-rate case.
Unsafe marshal deserialization	Medium / Bandit B302	64	Loading a crafted binary file through marshal.loads uses an unsafe serialization format.	Store and load application records as JSON and verify the top-level value is an object.
Shared mutable default argument	Medium / Pylint W0102	20	The default history=[] persisted changes between calls and had no clear purpose.	Removed the unused history parameter and its cross-call state.
Predictable application IDs	Low / Bandit B311	51	random.randint is predictable and unsuitable for identifiers that should resist guessing.	Generate IDs with secrets.randbelow.
Hardcoded bureau password	Low / Bandit B107	67	A password was embedded in source and used as a default argument.	Removed the password parameter and read an API token from the environment.
Shell mail dependency	Low / Bandit B404, B607, B603	6, 73-74	The program invoked a platform-specific executable and ignored its exit status.	Replaced it with TLS SMTP and credentials supplied through environment configuration.
PEP 8 and naming violations	Style / Pylint and Flake8	Throughout	The original had naming, line-length, spacing, docstring, and unused-import findings.	Renamed functions to snake_case, added documentation, removed unused code, and formatted lines to pass Flake8.

Observed demo improvements

A 500,000 loan at 9% over five years now produces a monthly EMI of about 10,379. The unsupported `crypto` product is rejected, the maximum principal accounts for interest, and a credit score of 950 is labeled invalid.

After Fixes: Clean Scanner Results

These snapshots show the final scanner status. The complete output is also preserved in the after-fix report appendix.

Pylint

AFTER FIXES - PYLINT

```
$ python -m pylint loan_calculator.py
--------------------------------------------------------------------
Your code has been rated at 10.00/10 (previous run: 10.00/10, +0.00)
```

Bandit

AFTER FIXES - BANDIT

```
$ python -m bandit -r loan_calculator.py
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.12.6
Run started:2026-10-30 13:22:04.858359+00:00

Test results:
        No issues identified.

Code scanned:
        Total lines of code: 189
        Total lines skipped (#nosec): 0
        Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
        Total issues (by confidence):
... excerpt continues in the full report appendix ...
```

Flake8

AFTER FIXES - FLAKE8

```
$ python -m flake8 loan_calculator.py
No Flake8 violations found.
```

Reflection

The supplied PDF states that four reflection questions are provided, but their wording is absent from the three-page handout. The responses below address four prompts based on the stated learning outcomes.

1. What does static analysis do, and what can it not prove?

Static analysis inspects source without running it. Pylint highlighted maintainability and logic-risk patterns, Flake8 caught formatting issues, and Bandit found unsafe transport, deserialization, and credential patterns. The tools helped focus the review, but they could not determine whether the loan policy itself was sensible or whether the EMI output was correct. Running the demo exposed the rate-unit bug and the approval of an unsupported loan type.

2. Which findings mattered most, and why?

The incorrect EMI and maximum-loan calculation could misstate a customer's repayment or affordable principal. The FTP transfer and embedded password could expose application data and credentials. I fixed those alongside unsafe deserialization and the invalid product approval because they affect correctness or sensitive data, not just readability.

3. How did the tools complement each other?

Pylint assessed code quality and produced a score, Flake8 gave precise style locations, and Bandit focused on security patterns. Their reports overlapped in places but did not replace one another. Manual inspection was still needed to interpret the business behavior and check the program's printed results.

4. What would I do differently in future development?

I would define units and valid input ranges at each function boundary, keep credentials outside source code, and run the three scanners as part of a repeatable development check. I would also keep a small set of expected calculation examples so that a clean static-analysis report is paired with evidence that the program still produces sensible results.

Appendix: Before Fixes Pylint Report

Complete contents of reports/before/pylint_report.txt.

```
************* Module loan_calculator
loan_calculator.py:79:0: C0325: Unnecessary parens after 'return' keyword (superfluous-parens)
loan_calculator.py:95:0: C0301: Line too long (113/100) (line-too-long)
loan_calculator.py:1:0: C0114: Missing module docstring (missing-module-docstring)
loan_calculator.py:14:0: C0116: Missing function or method docstring (missing-function-docstring)
loan_calculator.py:14:0: C0103: Function name "calculateEMI" doesn't conform to snake_case naming
   style (invalid-name)
loan_calculator.py:20:0: C0116: Missing function or method docstring (missing-function-docstring)
loan_calculator.py:20:0: C0103: Function name "checkEligibility" doesn't conform to snake_case
   naming style (invalid-name)
loan_calculator.py:20:0: W0102: Dangerous default value [] as argument (dangerous-default-value)
loan_calculator.py:20:0: R0913: Too many arguments (6/5) (too-many-arguments)
loan_calculator.py:20:0: R0917: Too many positional arguments (6/5) (too-many-positional-arguments)
loan_calculator.py:28:4: R1703: The if statement can be replaced with 'return bool(test)'
   (simplifiable-if-statement)
loan_calculator.py:28:4: R1705: Unnecessary "else" after "return", remove the "else" and de-indent
   the code inside it (no-else-return)
loan_calculator.py:28:7: R1714: Consider merging these comparisons with 'in' by using 'loan_type in
   ('home', 'car', 'personal')'. Use a set instead if elements are hashable. (consider-using-in)
loan_calculator.py:33:0: C0116: Missing function or method docstring (missing-function-docstring)
loan_calculator.py:33:0: C0103: Function name "maxLoanAmount" doesn't conform to snake_case naming
   style (invalid-name)
loan_calculator.py:34:4: W0622: Redefining built-in 'sum' (redefined-builtin)
loan_calculator.py:33:40: W0613: Unused argument 'annual_rate' (unused-argument)
loan_calculator.py:36:8: W0612: Unused variable 'month' (unused-variable)
loan_calculator.py:40:0: C0116: Missing function or method docstring (missing-function-docstring)
loan_calculator.py:40:0: C0103: Function name "amortisationSchedule" doesn't conform to snake_case
   naming style (invalid-name)
loan_calculator.py:50:0: C0116: Missing function or method docstring (missing-function-docstring)
loan_calculator.py:50:0: C0103: Function name "applicationId" doesn't conform to snake_case naming
   style (invalid-name)
loan_calculator.py:53:0: C0116: Missing function or method docstring (missing-function-docstring)
loan_calculator.py:53:0: C0103: Function name "saveApplication" doesn't conform to snake_case naming
    style (invalid-name)
loan_calculator.py:56:8: R1732: Consider using 'with' for resource-allocating operations
   (consider-using-with)
loan_calculator.py:61:0: C0116: Missing function or method docstring (missing-function-docstring)
loan_calculator.py:61:0: C0103: Function name "loadApplications" doesn't conform to snake_case
   naming style (invalid-name)
loan_calculator.py:62:4: W0603: Using the global statement (global-statement)
loan_calculator.py:63:8: R1732: Consider using 'with' for resource-allocating operations
   (consider-using-with)
loan_calculator.py:67:0: C0116: Missing function or method docstring (missing-function-docstring)
loan_calculator.py:67:0: C0103: Function name "uploadToBureau" doesn't conform to snake_case naming
   style (invalid-name)
loan_calculator.py:70:60: R1732: Consider using 'with' for resource-allocating operations
   (consider-using-with)
loan_calculator.py:73:0: C0116: Missing function or method docstring (missing-function-docstring)
loan_calculator.py:73:0: C0103: Function name "notifyApplicant" doesn't conform to snake_case naming
    style (invalid-name)
loan_calculator.py:74:4: W1510: 'subprocess.run' used without explicitly defining the value for
   'check'. (subprocess-run-check)
loan_calculator.py:76:0: C0116: Missing function or method docstring (missing-function-docstring)
loan_calculator.py:76:0: C0103: Function name "interestSaved" doesn't conform to snake_case naming
   style (invalid-name)
loan_calculator.py:81:0: C0116: Missing function or method docstring (missing-function-docstring)
loan_calculator.py:81:0: C0103: Function name "riskBand" doesn't conform to snake_case naming style
   (invalid-name)
loan_calculator.py:82:4: R1705: Unnecessary "elif" after "return", replace only that "elif" with
   "if" (no-else-return)
loan_calculator.py:93:0: C0116: Missing function or method docstring (missing-function-docstring)
loan_calculator.py:104:10: W1309: Using an f-string that does not have any interpolated variables
   (f-string-without-interpolation)
loan_calculator.py:2:0: W0611: Unused import math (unused-import)

-----------------------------------
Your code has been rated at 5.17/10
```

Appendix: Before Fixes Bandit Report

Complete contents of reports/before/bandit_report.txt.

```
Downloading pygments (1.2MiB)
 Downloaded pygments
Installed 8 packages in 1.15s
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.12.6
Run started:2026-10-30 13:16:46.870230+00:00

Test results:
>> Issue: [B402:blacklist] A FTP-related module is being imported.  FTP is considered insecure. Use
   SSH/SFTP/SCP or some other encrypted protocol.
   Severity: High   Confidence: High
   CWE: CWE-319 (https://cwe.mitre.org/data/definitions/319.html)
   More Info:
   https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.html#b402-import-ftplib
   Location: .\loan_calculator.py:3:0
2       import math
3       import ftplib
4       import marshal

--------------------------------------------------
>> Issue: [B404:blacklist] Consider possible security implications associated with the subprocess
   module.
   Severity: Low   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info:
   https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.html#b404-import-subprocess
   Location: .\loan_calculator.py:6:0
5       import random
6       import subprocess
7       from datetime import datetime

--------------------------------------------------
>> Issue: [B311:blacklist] Standard pseudo-random generators are not suitable for
   security/cryptographic purposes.
   Severity: Low   Confidence: High
   CWE: CWE-330 (https://cwe.mitre.org/data/definitions/330.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b311-random
   Location: .\loan_calculator.py:51:23
50      def applicationId():
51          return "LN-" + str(random.randint(10000000, 99999999))
52

--------------------------------------------------
>> Issue: [B302:blacklist] Deserialization with the marshal module is possibly dangerous.
   Severity: Medium   Confidence: High
   CWE: CWE-502 (https://cwe.mitre.org/data/definitions/502.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b302-marshal
   Location: .\loan_calculator.py:64:19
63          f = open(file, "rb")
64          applications = marshal.loads(f.read())
65          f.close()

--------------------------------------------------
>> Issue: [B107:hardcoded_password_default] Possible hardcoded password: 'Bureau#2024'
   Severity: Low   Confidence: Medium
   CWE: CWE-259 (https://cwe.mitre.org/data/definitions/259.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b107_hardcoded_password_default.html
   Location: .\loan_calculator.py:67:0
66
67      def uploadToBureau(report_path, user="loanops", password="Bureau#2024"):
68          ftp = ftplib.FTP(BUREAU_HOST)
69          ftp.login(user, password)
70          ftp.storbinary("STOR " + os.path.basename(report_path), open(report_path, "rb"))
71          ftp.quit()
72

--------------------------------------------------
>> Issue: [B321:blacklist] FTP-related functions are being called. FTP is considered insecure. Use
   SSH/SFTP/SCP or some other encrypted protocol.
   Severity: High   Confidence: High
   CWE: CWE-319 (https://cwe.mitre.org/data/definitions/319.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b321-ftplib
   Location: .\loan_calculator.py:68:10
67      def uploadToBureau(report_path, user="loanops", password="Bureau#2024"):
68          ftp = ftplib.FTP(BUREAU_HOST)
69          ftp.login(user, password)

--------------------------------------------------
>> Issue: [B607:start_process_with_partial_path] Starting a process with a partial executable path
```

```
   Severity: Low   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info:
   https://bandit.readthedocs.io/en/1.9.4/plugins/b607_start_process_with_partial_path.html
   Location: .\loan_calculator.py:74:4
73      def notifyApplicant(email, status):
74          subprocess.run(["mail", "-s", "Loan " + status, email])
75

--------------------------------------------------
>> Issue: [B603:subprocess_without_shell_equals_true] subprocess call - check for execution of
   untrusted input.
   Severity: Low   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info:
   https://bandit.readthedocs.io/en/1.9.4/plugins/b603_subprocess_without_shell_equals_true.html
   Location: .\loan_calculator.py:74:4
73      def notifyApplicant(email, status):
74          subprocess.run(["mail", "-s", "Loan " + status, email])
75

--------------------------------------------------

Code scanned:
        Total lines of code: 91
        Total lines skipped (#nosec): 0
        Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 5
                Medium: 1
                High: 2
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 1
                High: 7
Files skipped (0):
```

Appendix: Before Fixes Flake8 Report

Complete contents of reports/before/flake8_report.txt.

```
Installed 4 packages in 253ms
loan_calculator.py:2:1: F401 'math' imported but unused
loan_calculator.py:14:1: E302 expected 2 blank lines, found 1
loan_calculator.py:20:1: E302 expected 2 blank lines, found 1
loan_calculator.py:20:80: E501 line too long (85 > 79 characters)
loan_calculator.py:33:1: E302 expected 2 blank lines, found 1
loan_calculator.py:40:1: E302 expected 2 blank lines, found 1
loan_calculator.py:50:1: E302 expected 2 blank lines, found 1
loan_calculator.py:53:1: E302 expected 2 blank lines, found 1
loan_calculator.py:55:80: E501 line too long (88 > 79 characters)
loan_calculator.py:61:1: E302 expected 2 blank lines, found 1
loan_calculator.py:67:1: E302 expected 2 blank lines, found 1
loan_calculator.py:70:80: E501 line too long (84 > 79 characters)
loan_calculator.py:73:1: E302 expected 2 blank lines, found 1
loan_calculator.py:76:1: E302 expected 2 blank lines, found 1
loan_calculator.py:78:80: E501 line too long (83 > 79 characters)
loan_calculator.py:81:1: E302 expected 2 blank lines, found 1
loan_calculator.py:93:1: E302 expected 2 blank lines, found 1
loan_calculator.py:95:80: E501 line too long (113 > 79 characters)
loan_calculator.py:96:80: E501 line too long (98 > 79 characters)
loan_calculator.py:100:80: E501 line too long (86 > 79 characters)
loan_calculator.py:104:11: F541 f-string is missing placeholders
loan_calculator.py:106:1: E305 expected 2 blank lines after class or function definition, found 1
```

Appendix: After Fixes Pylint Report

Complete contents of reports/after/pylint_report.txt.

```
--------------------------------------------------------------------
Your code has been rated at 10.00/10 (previous run: 10.00/10, +0.00)
```

Appendix: After Fixes Bandit Report

Complete contents of reports/after/bandit_report.txt.

```
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.12.6
Run started:2026-10-30 13:22:04.858359+00:00

Test results:
        No issues identified.

Code scanned:
        Total lines of code: 189
        Total lines skipped (#nosec): 0
        Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
Files skipped (0):
```

Appendix: After Fixes Flake8 Report

Complete contents of reports/after/flake8_report.txt.

```
No Flake8 violations found.
```